

XX 國際股份有限公司

資通安全風險管理程序書



機密等級：☒一般 ☐敏感 ☐機密

編號：I-2-02

版本：1.0

發行日期：112 年 2 月 1 日

文件制／修訂紀錄頁

版次	發行日期	修訂摘要	修訂者	文管人員
1.0	112.2.1	初次發行	呂 oo	呂 oo

目錄

<u>內容</u>	<u>頁次</u>
壹、目的	3
貳、適用範圍	3
參、權責	3
肆、名詞定義	3
伍、作業說明	4
陸、相關文件與使用表單	6

壹、目的：

為建立 **XX 國際股份有限公司**（以下簡稱本公司）之資訊安全管理制度（以下簡稱 ISMS）風險評鑑與管理規範，提供本公司資訊資產之權責單位、保管單位及使用單位，共同遵行之風險評鑑標準，有效執行風險控管，預防資通安全事件之發生。

貳、適用範圍：

本公司範圍內資通安全業務作業流程之風險管理。

參、權責：

- 一、資通安全長：每年主持**資通安全暨個資保護委員會**，定期審議**資通安全**風險評鑑結果。
- 二、管理代表：負責決定**資通安全**可接受風險值，審核**資通安全**風險評鑑結果、**資通安全**風險處理改善計畫與安全控制措施。
- 三、工作小組：負責彙整各「資訊資產權責單位」資訊資產之**資通安全**風險評鑑，追蹤管制**資通安全**風險處理改善結果，定期產出**資通安全風險評鑑報告(I-2-02-02)**。
- 四、資訊資產權責單位：依據各單位業務範圍內盤點產出之**資訊資產清冊(I-2-08-01)**，進行**資通安全**風險評鑑(如資訊資產之威脅與弱點評估、風險值計算等)及**資通安全**風險處理改善作業，定期產出相關紀錄文件。

肆、名詞定義：

- 一、機密性 (Confidentiality):確保僅授權人員可存取資訊。
- 二、完整性 (Integrity):確保資訊與處理方法的正確性與完整性。
- 三、可用性 (Availability):確保經授權的使用者在需要時可以取得資訊及相關資產。
- 四、可接受風險值:各類資訊資產之最低風險容忍度。
- 五、殘餘風險 (Residual Risk):實施相關資安控制措施之後剩餘的風險。
- 六、威脅 (Threat):可能對系統或組織造成傷害之意外事件。

七、弱點 (Vulnerability):因資訊資產本身狀況或所處環境之下，可能受到威脅利用而造成資產受到損害之因子。

八、風險 (Risk):可能對團體或組織的資產發生損失或傷害的潛在威脅，通常利用弱點所產生之影響及發生可能性來衡量。

伍、作業說明：

一、鑑別資產：

(一) 資訊資產應依據「**資訊資產管理程序書(I-2-08)**」進行鑑別及分類。

二、鑑別風險：

(二) 威脅暨弱點評估

1. 威脅成功利用弱點影響資訊資產運作或造成損失的狀況稱為事件。
2. 依據威脅及弱點評鑑標準進行下列各類資訊資產之威脅及弱點等級評估：
 - (1) 人員 (People / PE)：包含因人員有意或無意行為、人力資源管理不當所產生之風險。
 - (2) 軟體 (Software System / SW)：包含系統設計、維護、操作之不當所產生之風險。
 - (3) 硬體 (Hardware System / HW)：包含所有硬體設施之失效、損毀等可能風險。
 - (4) 文件 (Document / DC)：包含資料、文件之建立、維護、控管、傳遞之不當所產生之風險。
 - (5) 資料 (Data / DA)：包含儲存於硬碟、磁帶、光碟等儲存媒介之數位資訊未依機密性進行存取控管造成資料外洩、誤用等風險。
 - (6) 環境 (Environment / EV)：包含天災、供水、用電、空調等，整體資訊環境，可能發生之風險。

3. 威脅及弱點評估標準等級對應如下

(1) 威脅發生機率評估標準

評估標準	等級	評估值
每年至少發生一次之可能性	低	1
每季至少發生一次之可能性	中	2
每月至少發生一次之可能性	高	3

(2) 弱點等級評估標準

評估標準	等級	評估值
該弱點不容易被威脅利用	低	1
該弱點容易被威脅利用	中	2
該弱點非常容易被威脅利用	高	3

(三) 風險值計算方式

1. 依據資訊資產管理程序書進行資訊資產價值評估計算。
2. 評估事件威脅發生機率及弱點影響程度後，依下列方法計算出風險值。

$$\text{風險值} = (\text{資訊資產價值} \times \text{威脅等級} \times \text{弱點等級})$$

(四) 資通安全風險評鑑工作表及資通安全風險評鑑報告

各「資訊資產權責單位」應依風險值計算方式，得參考「資通安全風險評鑑作業說明書(I-3-01)」產生各單位之「資通安全風險評鑑工作表(I-2-02-01)」，並提交資通安全工作小組彙整，作為本公司產出年度資通安全風險評鑑報告(I-2-02-02)之參據。

三、風險處理與持續改善：

(一) 資通安全可接受風險值的決定

1. 本公司資訊資產之資通安全可接受風險值，由「資通安全暨個資保護委員會」授權「管理代表」決定之。
2. 本公司資訊資產之資通安全可接受風險值，由「資通安全暨個資保護委員會」每年召開「管理審查」會議之時機，同步檢討審議「資通安全風險評鑑報告(I-2-02-02)」及資通安全「可接受風險值」之適切性。

3. 組織資通安全可接受風險值應考量組織內外環境及資通安全作業安全需求，予以適切調整。

(二) 本公司各「資訊資產權責單位」應依據「資通安全風險評鑑工作表(I-2-02-01)」評估結果，應將風險值超出可接受風險值者，選擇適當控管措施，進行必要之風險處理。

(三) 資通安全風險處理與選擇控制措施

1. 各「資訊資產權責單位」應依據「資通安全風險評鑑報告(I-2-02-02)」產出「資通安全風險處理改善計畫表(I-2-02-03)」，並提報管理審查會議審議，並列入追蹤管制。
2. 本公司各資訊資產權責單位之「資通安全風險處理改善計畫表(I-2-02-03)」應由資通安全工作小組彙整控管、持續追蹤，以確保確實完成資通安全風險處理之改善計畫。
3. 各資訊資產權責單位應於各資通安全風險處理改善計畫完成後，進行資通安全風險再評估，並經各單位權責主管審核，以確保相關改善措施的有效性。

(四) 資通安全風險處理與持續改善

1. 本公司應維持本資通安全風險評鑑方法之有效性與適用性，資通安全暨個資保護委員會授權管理代表指導資通安全工作小組得適時檢討修訂可接受風險值、威脅及弱點評估表等項目，以確保資訊資產受到適當保護。
2. 各資訊資產權責單位之「資通安全風險處理改善計畫表(I-2-02-03)」，應提報管理審查會議審議，並列入追蹤管制。
3. 每年應至少執行 1 次風險評鑑。
4. 新增系統、系統有重大異動或資通安全作業環境改變時，得不定期執行資通安全風險評估。

陸、相關文件與使用表單：

一、相關文件：

- (一) 資通安全暨個人資料保護組織管理程序書(I-2-06)
- (二) 資訊資產管理程序書(I-2-08)
- (三) 資訊資產清冊(I-2-08-01)
- (四) 資通安全風險評鑑作業說明書(I-3-01)

二、使用表單：

- (一) 資通安全風險評鑑工作表(I-2-02-01)
- (二) 資通安全風險評鑑報告(I-2-02-02)
- (三) 資通安全風險處理改善計畫表(I-2-02-03)